

System Hardening Report

Ubuntu Server 22.04 LTS — Security Baseline with Lynis

Author: Víctor Borrero

Date: June 2026

Version: 1.0

Classification: Confidential

This report was produced in a controlled laboratory environment for educational purposes only. All systems analysed are virtual machines configured specifically for defensive security practice.

Contents

1	Executive Summary	2
2	Scope and Methodology	3
2.1	Lab Environment	3
2.2	Tools Used	3
2.3	Methodology	3
3	Baseline Audit	5
3.1	Initial State	5
3.2	Prioritisation Criteria	6
4	Applied Measures	7
4.1	Measures Summary	7
4.2	Measure 1 — Firewall (UFW)	8
4.3	Measure 2 — Fail2ban	8
4.4	Measure 3 — Password Policy	9
4.5	Measure 4 — GRUB Bootloader Password	10
4.6	Measure 5 — Legal Warning Banner	11
4.7	Measure 6 — Rootkit and Malware Scanner	11
4.8	Measure 7 — Audit Framework (auditd)	12
4.9	Measure 8 — File Integrity Monitoring (AIDE)	13
4.10	Measure 9 — SSH Configuration Hardening	13
5	Results	14
5.1	Hardening Index Progression	14
5.2	Suggestions Comparison	15
6	Conclusions	16
6.1	Future Work	16

1. Executive Summary

This report documents a system hardening process applied to a freshly installed Ubuntu Server 22.04 LTS instance, using **Lynis** as the auditing and benchmarking tool. The objective was to identify configuration weaknesses on a default installation, apply a prioritised set of security measures, and verify their effectiveness through repeated, quantifiable audits.

Unlike a penetration test, which evaluates a system from an attacker's perspective, this project takes a defensive approach: starting from a default configuration and systematically reducing its attack surface, strengthening authentication, and adding detection capabilities.

The system's Lynis **Hardening Index** improved from **62/100** to **74/100** (+12 points, +19%) across three audit cycles, following the application of nine prioritised security measures.

2. Scope and Methodology

2.1 Lab Environment

Parameter	Value
Target system	Ubuntu Server 22.04 LTS (Jammy Jellyfish)
Hypervisor	VMware Workstation Pro
Network	NAT
RAM / vCPU	2 GB / 2 cores
Disk	20 GB
Remote access	OpenSSH Server
Date	June 2026

Table 2.1: Lab environment configuration

2.2 Tools Used

Tool	Version	Purpose
Lynis	3.1.6	Security auditing and hardening benchmark
UFW	—	Firewall management (iptables frontend)
Fail2ban	—	Brute-force protection for SSH
Rkhunter	—	Rootkit and malware detection
Auditd	—	Kernel-level security event auditing
AIDE	—	File integrity monitoring

Table 2.2: Tools used during the hardening process

2.3 Methodology

The process followed an iterative audit-harden-verify cycle:

1. **Baseline audit** — Initial Lynis scan on the default installation to establish a starting Hardening Index and list of suggestions
2. **Prioritisation** — Suggestions were grouped by risk impact and relevance; low-impact or infrastructure-dependent items were explicitly deferred with justification
3. **Remediation** — Application of nine security measures covering network filtering, authentication, boot security, and threat detection

4. **Verification** — Two subsequent Lynis audits to measure the quantifiable impact of the applied measures

3. Baseline Audit

3.1 Initial State

The first Lynis scan was run immediately after the operating system update, before any hardening measure was applied.

Metric	Value
Hardening Index	62 / 100
Tests performed	252
Suggestions generated	37
Firewall	Not active
Intrusion detection software	Not installed
Malware scanner	Not installed

Table 3.1: Baseline audit results

```
Scan mode:
Normal [#]  Forensics [ ]  Integration [ ]  Pentest [ ]

Lynis modules:
- Compliance status      [?]
- Security audit         [V]
- Vulnerability scan     [V]

Details:
Hardening index : 62 [#####          ]
Tests performed : 252
Plugins enabled : 1

Software components:
- Firewall              [X]
- Intrusion software    [X]
- Malware scanner       [X]

Files:
- Test and debug information : /var/log/lynis.log
- Report data                : /var/log/lynis-report.dat
```

Figure 3.1: Initial Lynis audit. Hardening Index: 62/100. Firewall, intrusion software and malware scanner all marked as absent.

3.2 Prioritisation Criteria

Of the 37 suggestions generated, nine were selected for remediation based on direct security impact and relevance to a server exposed to network access. The remaining items were explicitly deferred for the reasons below:

- **Separate partitions for /home and /var** — Would require reinstalling the system with a different disk layout; not applicable retroactively.
- **Disabling uncommon network protocols (dccp, sctp, rds, tipc)** — Low real-world risk in this scenario; deprioritised in favour of higher-impact measures.
- **External logging host** — Requires a second server to receive centralised logs; out of scope for a single-machine lab.
- **Package management auxiliary tools (apt-listbugs, apt-listchanges, debsums, apt-show-versions)** — Low direct security impact.

4. Applied Measures

4.1 Measures Summary

#	Measure	Lynis ID(s) addressed
1	Firewall (UFW), default-deny policy	FIRE-4590
2	Fail2ban for SSH brute-force protection	DEB-0880
3	Password policy (length, complexity, expiry)	AUTH-9230, AUTH-9262, AUTH-9286
4	GRUB bootloader password	BOOT-5122
5	Legal warning banner (local + SSH)	BANN-7126, BANN-7130
6	Rootkit/malware scanner (rkhunter)	HRDN-7230
7	SSH root login disabled	— (rkhunter finding)
8	Audit framework (auditd)	ACCT-9628
9	File integrity monitoring (AIDE)	FINT-4350

Table 4.1: Summary of applied hardening measures

4.2 Measure 1 — Firewall (UFW)

RESOLVED Lynis ID: FIRE-4590

Description: The system had no active firewall, leaving all services reachable without any network-level filtering. UFW (Uncomplicated Firewall) was installed and configured with a default deny incoming policy, allowing only SSH (port 22/tcp) as an explicit exception.

Command applied:

```
sudo ufw allow ssh
sudo ufw enable
```

```
victor@victor:~$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
22/tcp ALLOW IN Anywhere
22/tcp (v6) ALLOW IN Anywhere (v6)

victor@victor:~$
```

Figure 4.1: UFW active with default-deny incoming policy and an explicit allow rule for SSH (22/tcp), IPv4 and IPv6.

Rationale: A default-deny policy minimises the attack surface to only the services that are explicitly required, instead of attempting to anticipate and block every possible threat individually.

4.3 Measure 2 — Fail2ban

RESOLVED Lynis ID: DEB-0880

Description: SSH was exposed without any protection against automated brute-force login attempts. Fail2ban was installed and configured to monitor authentication failures and automatically ban offending IP addresses.

Configuration applied (/etc/fail2ban/jail.local):

```
[sshd]
enabled = true
```

```
port = 22
maxretry = 5
bantime = 600
findtime = 600
```

```
victor@victor:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
  |- Filter
  |   |- Currently failed: 0
  |   |- Total failed: 0
  |   `-- Journal matches: 0
  `-- Actions
      |- Currently banned: 0
      |- Total banned: 0
      `-- Banned IP list: 0
victor@victor:~$
```

Figure 4.2: Fail2ban jail for SSH active and monitoring authentication failures via systemd journal.

Rationale: After five failed login attempts within a 10-minute window, the offending IP is banned for 10 minutes, significantly raising the cost of automated brute-force attacks.

4.4 Measure 3 — Password Policy

RESOLVED Lynis IDs: AUTH-9230, AUTH-9262, AUTH-9286

Description: The system had no password strength requirements and no password expiration policy. `libpam-pwquality` was installed to enforce complexity rules, and password ageing was configured in `login.defs`.

Configuration applied (`/etc/security/pwquality.conf`):

```
minlen = 12
dcredit = -1
ucredit = -1
lcredit = -1
ocredit = -1
```

Configuration applied (`/etc/login.defs`):

```
PASS_MAX_DAYS    90
PASS_MIN_DAYS    1
```

```

victor@victor:~$ cat /etc/security/pwquality.conf | grep -v "^#"
cat /etc/login.defs | grep PASS_
minlen = 12
dcredit = -1
ucredit = -1
lcredit = -1
ocredit = -1
# PASS_MAX_DAYS   Maximum number of days a password may be used.
# PASS_MIN_DAYS   Minimum number of days allowed between password changes.
# PASS_WARN_AGE   Number of days warning given before a password expires.
PASS_MAX_DAYS    90
PASS_MIN_DAYS    1
PASS_WARN_AGE    7
victor@victor:~$

```

Figure 4.3: Active password quality and expiration policy: minimum 12 characters, full complexity requirements, 90-day maximum age.

Note: As `login.defs` only affects newly created accounts, the expiration policy was additionally applied retroactively to the existing `victor` user with `chage -M 90 -m 1 victor`, to ensure the policy was effective rather than only declarative.

```

victor@victor:~$ sudo chage -M 90 -m 1 victor
victor@victor:~$ sudo chage -l victor
Último cambio de contraseña                : jun 11, 2026
La contraseña caduca                        : sep 09, 2026
Contraseña inactiva                         : nunca
La cuenta caduca                            : nunca
Número de días mínimo entre cambio de contraseña : 1
Número de días máximo entre cambio de contraseña : 90
Número de días de aviso antes de que caduque la contraseña : 7

```

Figure 4.4: Effective password expiration applied to the existing user account.

4.5 Measure 4 — GRUB Bootloader Password

RESOLVED Lynis ID: BOOT-5122

Description: The GRUB bootloader had no password protection, allowing anyone with console access to alter boot parameters or enter single-user mode, potentially by-passing authentication entirely. A PBKDF2-hashed password was configured to require authentication for any boot configuration changes, while leaving normal system startup unaffected.

```

victor@victor:~$ grub-mkpasswd-pbkdf2
Enter password:
Reenter password:
PBKDF2 hash of your password is grub.pbkdf2.sha512.10000.7300A59554B9C86535191B4D7681EDCC931F330F6C13171FE36C945DA82055BFCE230F626328E66A6FF9DCDDC2798B7EE6ED08A0D91DC
D41480EC02B154A4CC.B8D9AD74851A722C2862A2E6499E6CBE1E267E8DE284A84E86320F0FC53F5F225AC30156E3345ACFAE9C94F5335A4BC7A611785115C50029C742489A3C7172F9

```

Figure 4.5: PBKDF2 password hash generated for GRUB authentication.

```

victor@victor:~$ sudo update-grub
Sourcing file `/etc/default/grub'
Sourcing file `/etc/default/grub.d/kdump-tools.cfg'
Generating grub configuration file ...
Found linux image: /boot/vmlinuz-7.0.0-22-generic
Found initrd image: /boot/initrd.img-7.0.0-22-generic
Found linux image: /boot/vmlinuz-7.0.0-14-generic
Found initrd image: /boot/initrd.img-7.0.0-14-generic
Warning: os-prober will not be executed to detect other bootable partitions.
Systems on them will not be added to the GRUB boot configuration.
Check GRUB_DISABLE_OS_PROBER documentation entry.
Adding boot menu entry for UEFI Firmware Settings ...
done

```

Figure 4.6: GRUB configuration successfully regenerated with the new authentication settings.

4.6 Measure 5 — Legal Warning Banner

RESOLVED Lynis IDs: BANN-7126, BANN-7130

Description: The system displayed no warning banner prior to authentication. A legal notice was added to both `/etc/issue` (local console) and `/etc/issue.net` (remote SSH access), with SSH explicitly configured to display it via the `Banner` directive.

```

(kali㉿kali)-[~]
$ ssh victor@192.168.239.130
*****
WARNING: This system is for authorized use only. Unauthorized
access or use is strictly prohibited and may be subject to
civil and criminal prosecution.
*****
victor@192.168.239.130's password: 

```

Figure 4.7: Legal warning banner displayed before SSH authentication.

Rationale: Beyond deterrence, an explicit access warning supports the legal pursuit of unauthorised access attempts under applicable computer crime legislation.

4.7 Measure 6 — Rootkit and Malware Scanner

RESOLVED Lynis ID: HRDN-7230

Description: No malware or rootkit detection capability was present. `rkhunter` was installed, its signature database updated, and a baseline scan performed against the clean system state.

```

System checks summary
=====
[ ]=FIRE-4590|Configure a firewall/packet filter to filter
File properties checks...
  Files checked: 183
  Suspect files: 0
[ ]=LOGG-2190|Check what deleted files are still in use and
Rootkit checks...
  Rootkits checked : 498
  Possible rootkits: 0
[ ]=BANN-7130|Add legal banner to /etc/issue.net, to warn un
Applications checks...
  All checks skipped
[ ]=ACCT-9628|Enable auditd to collect audit information|+
The system checks took: 16 minutes and 1 second
All results have been written to the log file: /var/log/rkhunter.log
One or more warnings have been found while checking the system.
Please check the log file (/var/log/rkhunter.log)

```

Figure 4.8: Rkhunter baseline scan: 183 files checked, 498 rootkit signatures checked, no suspicious findings.

Note: The scan flagged the SSH `PermitRootLogin` directive as unset. This was addressed directly by explicitly setting `PermitRootLogin no`, ensuring administrators authenticate as standard users and elevate privileges via `sudo`, rather than logging in directly as root.

4.8 Measure 7 — Audit Framework (auditd)

RESOLVED Lynis ID: ACCT-9628

Description: No kernel-level audit logging was in place. `auditd` was installed and a watch rule configured on `/etc/passwd` to record any write or attribute changes, persisted across reboots.

Rule applied:

```
auditctl -w /etc/passwd -p wa -k passwd_changes
```

```

victor@victor:~$ sudo auditctl -w /etc/passwd -p wa -k passwd_changes
Old style watch rules are slower
victor@victor:~$ sudo auditctl -l
-w /etc/passwd -p wa -k passwd_changes

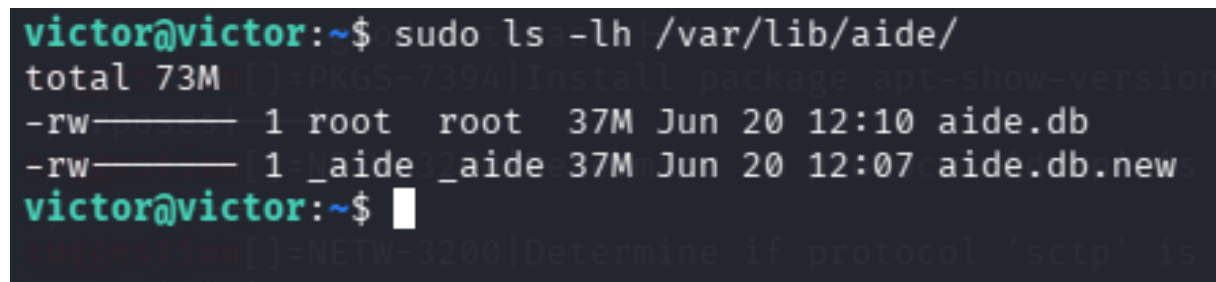
```

Figure 4.9: Active audit rule monitoring write and attribute changes on `/etc/passwd`, tagged for traceability.

4.9 Measure 8 — File Integrity Monitoring (AIDE)

RESOLVED Lynis ID: FINT-4350

Description: No mechanism existed to detect unauthorised modification of critical system files or binaries. AIDE was installed and a reference database of cryptographic checksums was generated to serve as the baseline for future integrity checks.



```
victor@victor:~$ sudo ls -lh /var/lib/aide/
total 73M
-rw-r--r-- 1 root root 37M Jun 20 12:10 aide.db
-rw-r--r-- 1 _aide _aide 37M Jun 20 12:07 aide.db.new
victor@victor:~$
```

Figure 4.10: AIDE reference database generated (37 MB), establishing the file integrity baseline for the system.

4.10 Measure 9 — SSH Configuration Hardening

APPLIED Identified after second audit cycle

Description: After the first round of measures, Lynis surfaced more granular SSH hardening suggestions, only flagged once the baseline configuration was already solid. The following directives were added to `/etc/ssh/sshd_config`:

```
Protocol 2
MaxAuthTries 3
LoginGraceTime 30
X11Forwarding no
PermitEmptyPasswords no
AllowTcpForwarding no
ClientAliveInterval 300
ClientAliveCountMax 2
```

Rationale: These directives reduce the SSH attack surface further: limiting authentication attempts and login time window, disabling unnecessary forwarding features, and automatically terminating idle or unresponsive sessions.

5. Results

5.1 Hardening Index Progression

Metric	Audit 1 (Baseline)	Audit 2	Audit 3 (Final)
Hardening Index	62 / 100	72 / 100	74 / 100
Tests performed	252	266	266
Firewall	Absent	Active	Active
Intrusion software	Absent	Active	Active
Malware scanner	Absent	Active	Active

Table 5.1: Hardening Index progression across the three audit cycles

```
Lynis security scan details:
[+]NETW-3200:Determine if protocol 'scrp' is really needed
Scan mode:
Normal [X] Forensics [ ] Integration [ ] Pentest [ ]
Lynis modules:
- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]
Details:
Hardening index : 72 [#####]
Tests performed : 266
Plugins enabled : 1
Software components:
- Firewall [V]
- Intrusion software [V]
- Malware scanner [V]
Files:
- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat
```

Figure 5.1: Second Lynis audit. Hardening Index: 72/100. Firewall, intrusion software and malware scanner now all active.


```

Lynis security scan details:

Scan mode:
Normal [■] Forensics [ ] Integration [ ] Pentest [ ]

File system
Lynis modules:
- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Details:
Hardening index : 74 [#####]
Tests performed : 266
Plugins enabled : 1

Software components:
- Firewall [V]
- Intrusion software [V]
- Malware scanner [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat

```

Figure 5.2: Final Lynis audit after SSH hardening. Hardening Index: 74/100.

5.2 Suggestions Comparison

Metric	Value
Suggestions before hardening	37
Suggestions after hardening	35
Directly resolved suggestions	10
New suggestions surfaced	10 (9 SSH refinements + 1 AIDE checksum algorithm)

Table 5.2: Lynis suggestions before and after hardening

Interpretation: The relatively small change in the total suggestion count does not reflect the depth of the work performed. Ten suggestions tied to structural gaps (firewall, brute-force protection, password policy, boot security, threat detection) were directly resolved. The new suggestions that appeared are not regressions: Lynis performs deeper SSH analysis only once a baseline level of security is detected, surfacing tuning recommendations that were not previously reachable. This reflects hardening as an iterative process rather than a one-time checklist.

6. Conclusions

The hardening process improved the system's Lynis Hardening Index from **62 to 74** (+19%) through nine prioritised, justified measures rather than a blanket application of every available suggestion. Each decision — both what was applied and what was explicitly deferred — was based on an assessment of real-world risk and relevance to a server exposed to network access.

Key outcomes:

- Network exposure reduced via a default-deny firewall policy
- Brute-force protection added for the primary remote access vector (SSH)
- Authentication strengthened through password policy and root login restrictions
- Boot-time tampering prevented via GRUB authentication
- Detection capabilities established for malware (rkhunter), file tampering (AIDE), and sensitive file changes (auditd)

The diminishing but still positive gain observed in the final audit cycle (+2 points after SSH-specific hardening, compared to +10 points after the initial measures) illustrates a common pattern in security hardening: the largest gains come from addressing structural gaps first, after which further improvements become progressively more incremental. This does not diminish their value, but reflects the maturing security posture of the system.

6.1 Future Work

The following items were identified but intentionally deferred, and are documented here as scope for future iterations:

- Separating `/home` and `/var` onto dedicated partitions
- Forwarding logs to a centralised external logging host
- Refining AIDE to use SHA-256/SHA-512 checksums explicitly
- Periodic automated execution of Lynis and rkhunter via cron, with alerting on score regression